PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Menaces et attaques réseau

09-400 PSE-ER F4-5 Menaces et attaques réseau — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'ingénierie sociale exploite les failles humaines : leviers du modèle MICE, fouille des déchets ou shoulder surfing.
2. Les menaces actives modifient l'état du système tandis que les menaces passives se limitent à l'observation comme l'écoute des lignes.
3. Le buffer overflow représente environ deux tiers des vulnérabilités et peut être contré par l'usage de fonctions bornées.

Synthèse des techniques d'attaques

Notion	À retenir
Facteur humain	L'**ingénierie sociale** exploite les failles humaines. Leviers **MICE** (VICE en français) : **argent**, **idéologie**, **compromission**, **ego/orgueil**. Techniques : fouille des déchets, **shoulder surfing**.
Écoute et balayage	**Sniffing** : capture de paquets sur réseau local non commuté. **Scanning** : recherche de ports ouverts. Un balayage sur tiers est une **tentative d'intrusion**.
Stéganographie	Dissimulation d'informations dans des fichiers (graphiques, sonores). Ex. **watermarking** ; logiciels `Steganos Security Suite`, `OutGuess`, `MP3Stego`.
Typologie menaces	**Actives** : panne, virus, vers, spyware, spam, phishing, chevaux de Troie, portes dérobées, dénis de service, intrusions, bombes logiques. **Passives** : écoute, analyse de trafic.
Codes malveillants	**Virus** (reproduction/propagation), **Vers** (se propagent seuls via réseau), **Cheval de Troie** (apparence légitime), **Spyware** (collecte d'infos), **Botnet** (réseau de bots piloté).
Messagerie	**Spam** (envoi massif non sollicité) et **Phishing** (hameçonnage pour voler données). Le **Scam** (fraude 419) vise l'extorsion de fonds.
Conséquences	Perte de **données**, de **temps de travail**, d'**image de marque**, de **fonctionnalités** (blocage) et de **confidentialité**.

Données clés et statistiques

90 %
des courriers échangés sont des spams

99 %
du spam est relayé par des machines de particuliers

1 / 4
des machines faisait partie d'un botnet (janvier 2007)
estimation de Vinton Cerf

154 millions
de machines dans les botnets
estimation de Vinton Cerf

6500
pages web associées au spam découvertes chaque jour
soit une toutes les 13 secondes

29 %
des utilisateurs achètent par l'intermédiaire d'un spam

400 000
machines dans le botnet de Jeanson James Ancheta (0x80)
condamné en 2006

Synthèse des vulnérabilités réseau

Notion	À retenir
Anciennes attaques IP	Fragmentation (`teardrop`), attaque `land` (source/destination identiques), ping de la mort (paquet > **65535** octets) ou `UDP Flood` (prioritaire sur TCP).
Le sniffer	Outil de visualisation de trames (droits **administrateur**, mode `promiscuous`). Exemples : `tcpdump` (Unix/Linux) ou **Wireshark** (multiplateforme).
Usurpation d'adresse	**IP spoofing** : parodie l'adresse IP pour accéder à des systèmes (ex: `rlogin`, `rsh`) via des numéros de séquence TCP prévisibles.
Déni de service	**DOS** (local ou réseau) ou **DDOS** (distribué, via botnet). Ex: `SYN flood` (état `SYN_RECV`) ou attaques historiques (ex: **Mafiaboy**, 2000).
Niveau liaison/applicatif	**ARP spoofing** (pollution cache), **TCP hijacking** (interception session), **Smurf** (ICMP echo request/diffusion) ou **DNS cache poisoning** (ex: **BIND**, CVE-2007-2926).

Synthèse des vulnérabilités applicatives et systèmes

Notion	À retenir
Débordement de tampon	Écrit hors zone (**pile** ou **tas**). Environ **2/3** des vulnérabilités. Utiliser des fonctions bornées : `strncpy`, `strncat` ou `scanf` avec largeur au lieu de `gets`, `strcpy`, `strcat`.
Chaînes de format et accès concurrents	Fonctions type `printf` ou `syslog` vulnérables. **Race condition** : manipulation simultanée de ressources. Rendre les opérations **atomiques** et utiliser `open`, `fstat`, `fdopen`.
Vulnérabilités du web	**XSS** (scripts exécutés dans le navigateur) : filtrer via `htmlspecialchars`. **Injection SQL** : vérifier les valeurs des formulaires. **IIS 4.0 et 5.0** : double décodage d'URL.
Sécurité des systèmes	Disponibilité : utiliser des **clusters** (Linux, Windows Server). Virtualisation (VMware, VirtualBox) : optimise les ressources mais risque de **panne de ressource commune**.

Synthèse des outils et menaces réseau

Notion	À retenir
Anatomie attaque	Récolte d'informations (**whois**, moteurs de recherche), analyse détaillée (**cartographie**, services, vulnérabilités) avant l'exploitation.
Cartographie réseau	Outils : `ping` (peu efficace), `Pinger`, `fping`, `hping3`, `nmap`. Test des règles pare-feu, MTU, trace route et empreintes OS.
Services ouverts	Outils : `nmap` (référence), `jakal`, `IdentTCPscan` (Unix), `ISS`, `YAPS` (Windows). `telnet` pour les bannières de version.
Failles/Vulnérabilités	Risques : négligence (mot de passe nul), erreur programmation, **zero day**. Suivre le **CERT**, **ANSSI**, **BugTraq**.
Scanners/Exploitation	Outils : `SATAN`, `Nessus` (langage **NASL**), `ISS`. Corrélation avec **BID** (SecurityFocus) ou **CVE** (MITRE).
Détection/Prévention	IDS (comportement/signatures) : `Snort` (NIDS). IPS (bloque trafic) : **Cisco**, **ISS**, **McAfee**.
Métrologie/Craquage	Métrologie : `extra`, `MRTG` (SNMP), `vigilog`. Craquage : `crack`, `John the Ripper` (Unix), `l0phtcrack` (Windows).
Rootkits	Dissimulation d'accès. Remplace `ps`, `netstat`, `ls`, nettoie `/var/log`. Détection : `chkrootkit`, `Tripwire`, `RootkitRevealer`.

Commandes et outils de recherche de services

Commande	À quoi ça sert
`nmap`	outil de référence pour scanner services, identité et empreinte OS
`netstat -anp / lsof`	association locale entre un port et un processus (Unix)
`Active Ports / tcpview`	association locale entre un port et un processus (Windows)
`telnet`	obtention de la version des services via la bannière
`hping`	scan en usurpant l'identité d'une autre machine
`p0f`	fingerprinting passif (analyse sans émission)

Pièges et confusions

- ⚠ Confondre le virus, qui se propage dans une machine, avec le ver, qui se propage seul à travers le réseau.
- ⚠ Confondre le XSS (Cross Site Scripting) avec le CSS (Cascading Style Sheet).
- ⚠ Confondre le cheval de Troie, qui se cache dans un logiciel légitime, avec le spyware, qui collecte des informations.
- ⚠ Confondre le scanning, qui est une recherche de ports, avec le sniffing, qui est une capture de paquets.
- ⚠ Confondre le phishing, technique d'ingénierie sociale par message, avec le scam, qui est une arnaque visant l'extorsion de fonds.

Sigles et définitions

MICE — Acronyme pour Money, Ideology, Compromise et Ego, recensant les leviers psychologiques pour retourner un agent.

Stéganographie — Procédé de dissimulation d'informations sensibles parmi d'autres informations moins importantes.

Botnet — Réseau de bots informatiques connectés à Internet et pilotés par un botmaster.

Phishing — Technique d'ingénierie sociale par courrier ou site web incitant à cliquer pour soutirer des données.

SYN flood — Déni de service par inondation de paquets SYN avec une adresse source usurpée, laissant la machine en état SYN_RECV.

Rootkit — Outil de dissimulation d'accès qui rend les commandes locales suspectes.

Auto-test

1. Quelle est la différence entre une menace active et une menace passive ?
2. Qu'est-ce qu'un scan de ports sur un tiers ?
3. Quel est le risque lié à la virtualisation ?
4. Comment appelle-t-on l'attaque consistant à faire chevaucher deux fragments IP ?
5. Quelle commande permet de visualiser l'état des connexions et de détecter un SYN flood ?

Réponses : **1.** La menace active modifie l'état du système, la menace passive se limite à l'observation. · **2.** Une technique de recherche de ports ouverts considérée juridiquement comme une tentative d'intrusion. · **3.** Une panne de ressource commune ou un défaut de cloisonnement peut compromettre tous les services hébergés. · **4.** Teardrop. · **5.** netstat.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.